How Corporate Culture Dictates Whether Organizations Care About the CIA Triad; and Extension Cybersecurity

Alvin, AT, Ton

Author, Western Washington University, tonk4@wwu.edu

CCS CONCEPTS • Corporate Culture • CIA Triad • Cybersecurity Employee Acceptance and Culture

Additional Keywords and Phrases: Breach, resilience, compliance, frameworks

1 INTRODUCTION

Corporate culture plays a decisive role in effective integration of cybersecurity within a company by influencing whether employees working within the organization take aspects of the CIA triad seriously [1]. Understanding that incorporating a risk-aware leadership, an environment that takes responsibility and accountability in security, along with transparency, and integrating security throughout the development life cycle helps reinforce aspects of cybersecurity [1].

2 CULTURE DEFINITION

Organizational culture is the set of behaviors and expectations that employees decide to follow [1]. Like a societal culture, a company culture is seen by what actions the majority of individuals belonging to the culture exhibit [1]. Contextually, this paper seeks to outline what actions should be taken to cultivate a company culture that values cybersecurity by incorporating cybersecurity practices.

3 CIA TRIAD DEFINITION

The CIA triad is a fundamental, high-level cybersecurity model that defines three core objectives to how to protect information, data, and general systems: Confidentiality, Integrity, and Availability (CIA) [2]. This model will be defined and used to incorporate cybersecurity practices into company culture.

3.1.1Defining Confidentiality

Confidentiality is an aspect in security that seeks to ensure that information is kept private, and only accessible to authorized entities. Only individuals who are allowed access should be the only ones given access [2]. If unauthorized individuals can gain access without the permission of the people to keep the data private, then confidentiality is broken, and thus part of the system is not secure [2]. The first step in applying confidentiality is to know what data needs to be protected. Financial records, medical records, business plans, company projects, are all examples of data and information that is advantageous to keep private [2]. Leaking of the plans and projects mentioned is equivalent to giving up a competitive lead or potentially giving information to threat actors who can use the information against the companies and individuals maliciously [2].

Secondly, there are different types of information and different method of storage dictates how the assets can be kept secret [2]. Records can have layers of information protection, like encryption to make sure that only the right key kept by authorized entities can read information in any meaningful way. Furthermore, access control lists, file permissions, and forms of authentication can help deny access to critical information unless the user can prove being an individual who should have authorized access [2].

3.1.2Defining Integrity

Integrity is another aspect in security that says that data should not be altered without authorized permission. Only individuals who are allowed access should be given the ability to alter the contents of the data. The value of secret information is only as useful as it is accurate [2]. If unauthorized individuals gain access and alter the contents of the asset, then integrity as a concept fails, and the data is significantly devalued. For example, altering data for a bank transfer of $50,000,000 when the intended amount is $500 could significantly harm the organization through financial loss, leading to legal and fraudulent related issues, a loss in stakeholder trust, and potentially disruption in company operations [2]. Integrity for this reason is highly valuable because companies that work with intentionally altered data could come back to harm the company.

Furthermore, authorized users must know that the data is kept accurate and is unchanged [2]. Integrity is enforced through methods like encryption and hashing [2]. Encryption comparisons can be a way to prove integrity though using algorithms to produce complex ciphertext that is deterministic in nature [2]. What this means is that if two copies of the same data are encrypted using the same algorithm, the same output will be produced in ciphertext [2]. The deterministic nature of encryption algorithms can be used to compare the ciphertext of the data from a previous session to the same data in a later session; and if the ciphertext is the same, it can be implicitly trusted that the data is unaltered [2]. Digital signatures and digital certificates apply encryption implies integrity by proving authenticity [2]. Non-repudiation is described to undeniably prove that a user made an action, and the encryption methods of digital signatures and certificates are used through a chain of trustworthy sources and in turn can be implicitly proven that the data is altered from an authorized user [2].

Logging user actions is another way to show when changes to certain information occur, who made the changes, and how the data was changed [2]. Whenever an individual accesses or manipulates the data, then the actions will be recorded and stored by monitoring tools [2]. This adds many security measures to see if data maintains integrity and keeps track of data that is sure to be unchanged [2].

3.1.3Defining Availability

Availability is the 3rd aspect in security that goes over how data should be accessible to authorized users whenever the user wants to access data [2]. Availability, then, is split into 2 considerations; is the system the system up and is the system in a state that can be accessed [2]. Much like how confidentiality and integrity is valued, data conditionally valuable only if it can be accessed and utilized when needed [2]. If systems, for any reason are down, the users who rely on the service being kept online cannot operate.

Methods to achieve integrity involve finding ways to make sure that the system cannot easily be taken down, and ways to find out how systems can be as available as possible in cases of incidents that lead to system downtime [2]. Firewalls, intrusion detection and prevention are ways to make sure that networks properly block incoming traffic and deny external malicious requests from unknown origins [3].

Proper access control lists help networks stop unusual activities that can lead to overloading a system and affecting the availability of services [2]. Introducing redundancy into a network works as a countermeasure to attacks that seek to overload systems [3]. Servers put on standby are used for this reason to make sure that if the main servers are offline, then there are other servers that can be deployed for the sole purpose of maintaining uptime.

3.2 Relating CIA to Cybersecurity and Culture

The CIA triad is a broad concept that seeks to introduce a baseline idea for how systems should be secured [2]. Even though the concept is high level and not very detailed, every aspect is used as scaffolding to begin creating more concrete policies, security controls, and overall more digitally secure infrastructure [2]. The CIA Triad and Cybersecurity seek to identify valuable assets and find ways to protect information so companies and users can continue operating as effectively as possible [2]. Like a wall protecting all fronts, the implementation of confidentiality, integrity, and availability makes systems more difficult to break into, and allows for companies to continue with business goals to grow and succeed [2]. Cybersecurity cannot be fully risk-resistant, but finding ways to mitigate as much as possible and having plans to consistently replicate best security practices makes sure that loss of assets and damage are kept to a minimum and in the long run saves money and stress over the potential loss of company assets [1,2].

The CIA triad is a model to enforce cybersecurity, and cybersecurity in turn is used within the organization to protect assets so resources can be consistently used for business goals [2]. Cybersecurity is valuable, but consistent cybersecurity is what makes the difference within a company to make sure that all assets can be covered [1]. Consistency within an organization is reflected through company culture, which is defined by what people value and how values are reflected through the actions taken within the companies' policies. So, the best way to incorporate cybersecurity is to integrate best security practices and introducing values to the current working culture to foster a systematic change in the views of how company systems and assets should be secured [1].

4 Risk-Aware Leadership Culture

A risk-aware leadership is a type of culture that seeks to introduce cybersecurity into a company environment through leading by example and integrating security as a core pillar of business operations. Often times, cybersecurity is treated as a concern for the

IT department that's set to the side, and this result leads to a culture that does not value or care about cybersecurity as much as is needed to optimally secure a company [4]. For security to be effective within a corporation, security practices must be implemented at all levels of company operation, and so the challenge starts with how to make a company care in the first place [1].

4.1 Leadership Acceptance in Cybersecurity

Introducing company-wide cybersecurity into a company, like many ideas that require a fundamental change into a company is difficult and requires time and money [1]. Proving to leadership that cybersecurity is cost-effective and worthwhile is the first step to prove that it is in the best interest of the company to value cybersecurity [1].

It is stated that data breaches in the past 3 years have increased by nearly 200% compared to the rest of the years before [3, 5]. Breaches in departments for manufacturing, technology & communications have increased by over 200% in the past 20 years, and healthcare related breaches have also increased by 300% in the same timeframe [5]. Nearly every field has received more data breaches by at least double, and the global average cost of a data breach in the United States costs $4.4 million per breach [6], with small business ranging from the lower $120,000 to $1.24 million, and enterprises averaging up to $4.9 million [7].

How, then, are costs in implementing cybersecurity within a company compared to the average losses of companies over the past few years? There are a lot of factors that cannot quantifiably measure without getting a quote, but the general costs in small businesses (fewer than 50 employees) tend to spend about $5,000-$50,000 per year on cybersecurity, while big businesses can allocate $250,000 to $5 million for large enterprises annually on cybersecurity [8]. This does not include logistics and the initial integration of security in the first place, but the average cost of breaches is increasing, and breaches are occurring more often across the board [8].

The board of directors of a company must consider that statistically, cybersecurity is becoming more valuable, and the costs in not taking steps in securing a corporation will cost more than integrating cybersecurity into the company culture [1]. Once the leaders begin to accept and value into security, then that becomes the first step in integrating security into a corporation [1].

4.2 Appointing Risk-Aware Leader

In practice, when security is integrated, leadership will often appoint a CISO (chief information security officer) who has the sole job and authority in helping the company identify business risks and set security strategies aligned with that risk [1]. CISOs will set up policies, controls, and standards related to security, enforce governance and compliance, and be an overall driver for the company's cultural approach to security [1]. By defining expectations, ethics, and beliefs, a culture is created from the top first, and sets the conditions of why the confidentiality, integrity, and availability model will help with securing core business goals [1]. Policies and controls driven by leadership will trickle down to the rest of upper, middle, and lower management [1].

However, leadership alone does not drive the creation of a culture. A roadblock that will be met in companies is convincing other levels of management to accept cybersecurity [1]. Employees will not accept ideas and beliefs simply because the upper management instructed the employees to do so [1]. Middle management and lower management directly manage employees within their own team, and if management doesn't lead by example by accepting cybersecurity, then the employees working under management most likely won't follow through either [1].

For this reason, there must be repercussions considered in policies and frameworks to make sure that all members are compliant, while also giving rewards and recognition for proper compliance in protocols [1]. Frameworks and rules must be set to make sure that certain aspects of security are embraced, and documented punishments if not followed [1]. COBIT is an example of a cybersecurity framework that focuses on management and leader rules on accountability, and governance [1]. ISO27001 is another framework that focuses on setting rules risk treatment, documentation, and a consistent strive for improvement through managed documentation, and security programs [1]. A security structure is only as effective as the weakest link, and security can only be prevalent if management accepts the idea of security with incentives to embrace the spreading of the culture [1].

4.2.1Risk-aware Employees

Employees who work under management will pick up values that ultimately stem from leadership. As an example, policies set by leadership can help enforce confidentiality by pushing processes that promote least-privilege access, multi-factor authentication, and more robust password and access controls [4].

Policies can introduce rigorous security testing during the development lifecycle, leading to systems that have integrity checks built in mind [1]. A focus on system resilience could be introduced because of expectations created by leadership, allowing systems to minimize availability threats and maximizing availability uptime. Employees do not value beliefs if the entities leading do not lead by example [4]. Cybersecurity is supported in a company when a conscious effort is made to systematically incorporate security, not as simply something the IT department only needs to worry about, but a core structure that is defined by a culture [1].

5 RACI DEFINITION

As an extension to leadership-led security processes and standards, a corporate culture that promotes aspects like responsibility and accountability ensures that policies are enforced and gives a way for employees to accept the idea of a culture of security [9]. Responsibility and Accountability is one half of a framework called RACI (Responsibility, Accountability, Consulted, Informed). RACI is a project management tool that when applied with security values, changes how projects will be approached throughout the project process [10]. Responsibility covers the people who are doing the work. Accountability is given to an individual who will sign off on the project given that the work in the project is complete and meets the quality and standards [10]. Consulted, then, lists the individuals who have the knowledge needed to complete the project. Informed, is the last, and covers individuals that need to be kept in the loop about any changes or decisions made regarding the work being done [10]. Figure 1 is an example of a model discussing members of a team being assigned roles according to RACI.

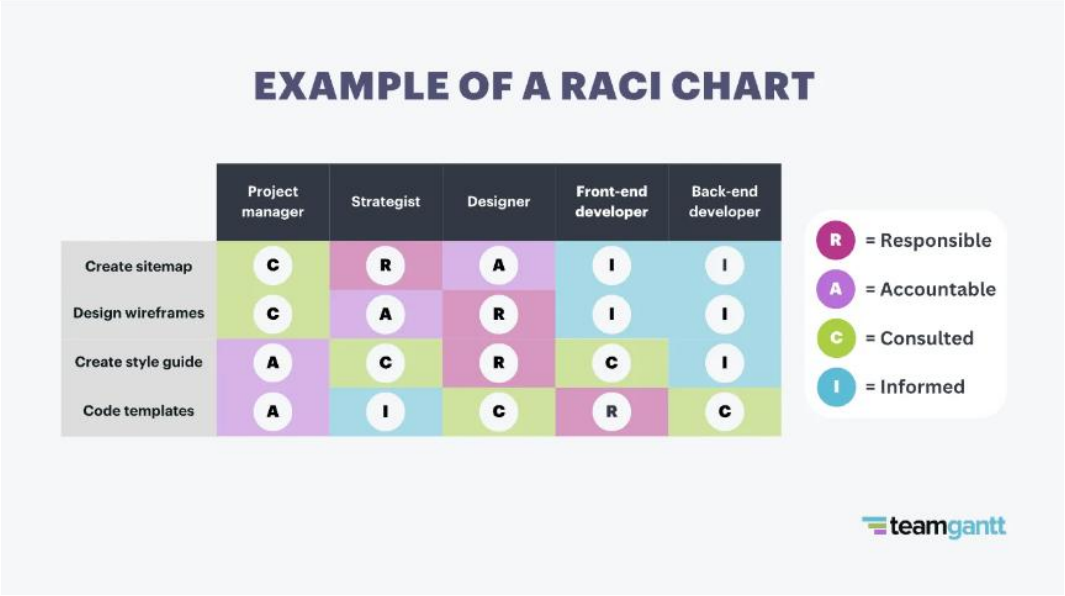

Figure 1: Example of a simple RACI chart. Image by teamgantt, VIA teamgantt.com. [10]

5.1 RACI & CIA Triad

When security is included within the RACI assignment process, security related issues become difficult to overlook. Security becomes part of the normal list of requirements that need to be completed when thought of in this way [10]. When responsibility is assigned to team members, processes need to remain compliant and promote confidentiality in data, data integrity, and system resilience [1]. Those who are accountable will sign off on tasks and projects after checking for quality for requirements including the ones that satisfy the CIA triad [1]. Members who are consulted have the expertise to educate and share information in how to secure the systems of the project. Informed individuals, like upper management will receive notice in the integration of requirements like security, and will know that security, even without needing to look into it deeply, is being considered [1].

Members embrace a culture like the incorporation of the CIA triad by seeing upper management preaching for security (which includes the CIA), seeing others following suit, and seeing the process being rewarded and not punished [1]. Accepting the idea cybersecurity, then, is not simply following the directions that the leaders want; it is instead genuinely embracing cybersecurity as a core value, and RACI directly facilitates the transition from acceptance to embracing of the incorporation of cybersecurity [1].

For these reasons, implementations of security into already existing processes like RACI help turn leadership values into cultural values by directly affecting how team members operate, which promotes cybersecurity by extension [10].

5.2 Secure SDLC

The secure software development life cycle (SSDLC) is the technical application of implementing security into company processes and is an extension of assigning RACI with security [11]. The software development life cycle talks about the different stages a project is during development. The life cycle details the requirements needed for the project to be accepted, to the development, testing, maintenance, and even the retirement of software. Security is introduced into the development life cycle to not only promote cybersecurity as a culture, but to also create more stable products [1].

When introducing security into a development lifecycle, requirements set by leadership will reflect right during a project's conception; project managers are responsible from the beginning to consider resilience, data confidentiality, integrity checks, and system logging to help with availability; all introduced within a business case [1]. And as projects extend into development and further into the lifecycle, a RACI chart is used by project managers to assign responsibilities to team members to complete tasks that now include security [10].

For organizations who don't value cybersecurity, security (if implemented at all) is often introduced during the testing phases of the development lifecycle [1]. A late introduction of cybersecurity makes development take longer by trying to force security into a mold that was never designed for it in the first place [1]. Testing for vulnerabilities should happen at all phases even before the actual testing phase, and often times bugs found at later stages of the lifecycle costs more money to backtrack and patch [11]. Finding bugs during the testing phase is 15x more expensive than finding a flaw in the requirements [12]. If cybersecurity was introduced at the start, then it is much more likely for vulnerabilities to be found earlier. The value in using security tools during development is to find vulnerabilities before the actual threats occur. What's the point of introducing security later if it needs to be added anyways?

It is more efficient to implement security in other stages of the development cycle. During the design phases, confidentiality through encryption of sensitive data and the usage of VPNs can help make sure that communication between different departments is kept secret [2]. Attackers who are listening to the ports would be unable to easily extract the contents of the traffic, so the data is kept confidential. Integrity in the form of systems logging and encryption can be used to ensure that data is not tampered with unknowingly, and introducing redundancy during integration can help maintain integrity of data [2]. Availability, then, can be introduced during testing to ensure that there are methods of recovery in the case of outages [2]. When CIA is implemented, the customer gets an overall more secure product that has the ability to defend, and repel threats, while simultaneously being able to protect data and maintain high availability through resilience [2].

6 CONCLUSION

For cybersecurity to be effective within a corporation, every member needs to be responsible for incorporating security [1]. Members have no reason to embrace a culture of cybersecurity in any process of the design of the company if leadership are not the first to champion the idea. Leadership must be the first to find value in cybersecurity, and by introducing policies, frameworks, and rules to enforce the idea that security is just as important as any other core department [1]. Afterwards, work needs to be done to ensure that security is enforced by other levels of management, and further efforts should be made to finally integrate security concepts into the very development life cycle to fully integrate security into a culture.

REFERENCES:

[1] E. Fretheim and M. Deschene. 2023. Secure Software Systems: Design and Development. Jones & Bartlett Learning, Burlington, MA. ISBN 9781284261158.

[2] Fortinet, Inc. 2025. *What is the CIA Triad and Why is it Important?*. Retrieved November 10, 2025 from https://www.fortinet.com/resources/cyberglossary/cia-triad

[3] SecurityScorecard. 2025. 10 Best Practices to Prevent DDoS Attacks, https://securityscorecard.com/blog/best-practices-to-prevent-ddos-attacks

[4] John Hintze. 2025. *The Characteristics of Effective Risk Leaders.* Risk Management Magazine, https://www.rmmagazine.com/articles/article/2025/07/31/the-characteristics-of-effective-risk-leaders

[5] Emily Bonnie. 2025. 110+ of the Latest Data Breach Statistics to Know for 2026 & Beyond, https://secureframe.com/blog/data-breach-statistics

[6] IBM. 2025. Cost of a data breach 2025 | IBM, https://www.ibm.com/reports/data-breach

[7] Alexis Porter. 2025. Impactful Big or Small: A Cost Comparison of Data Breaches, https://bigid.com/blog/a-cost-comparison-of-data-breaches

[8] Val Tsanav. 2025. Cost of Cybersecurity for Small Businesses in 2025, https://www.execweb.com/post/cost-of-cybersecurity-for-small-businesses

[9] Esther Han. 2023. *How to Create a Culture of Ethics & Accountability in the Workplace.* Harvard Business School Online, https://online.hbs.edu/blog/post/ethics-and-accountability-in-the-workplace

[10] Brett Harned. 2025. *What Is a RACI Chart? Practical Examples & Project Uses.* TeamGantt, https://www.teamgantt.com/blog/raci-chart-definition-tips-and-example#what-is-a-raci-chart

[11] Palo Alto Networks. n.d. *What Is Secure Software Development Lifecycle (Secure SDLC)?*, https://www.paloaltonetworks.com/cyberpedia/what-is-secure-software-development-lifecycle#sdlc

[12] Tamas Cser. 2023. *The Cost of Finding Bugs Later in the SDLC,* https://www.functionize.com/blog/the-cost-of-finding-bugs-later-in-the-sdlc